BÁO CÁO CÁC LỖI CẤY THÊM NGOÀI ĐẶC TẢ SRS

> **Môn học:** Đảm bảo Chất lượng Phần mềm (SQA) - BCSE2023
> **Hệ thống:** Mini HRM Leave Portal (v3.3)
> **Tài liệu quy chiếu:** `SRS_Leave_Management_System.md`

2. Bảng tổng hợp 3 lỗi

Mã Bug	Tên lỗi	Phân loại	Mức độ	Vị trí
BUG-01-LOW	Vỡ giao diện bảng lịch sử khi lý do chứa chuỗi dài liên tục không ngắt quãng	UI/UX Display Glitch	Low	`EmployeeDashboard.tsx`
BUG-02-MEDIUM	Tạo đơn nghỉ phép trùng lặp do thiếu Debounce/Disable nút gửi	Functional / Race Condition	Medium	`EmployeeDashboard.tsx`
BUG-03-HIGH	Lỗ hổng IDOR cho phép nhân viên rút/hủy đơn của người khác	Security / Broken Access Control	High	`leave.service.ts`

3. Chi tiết từng lỗi & Hướng dẫn kiểm thử

🟢 BUG-01-LOW: Vỡ layout bảng khi nhập lý do dài không có khoảng cách

Vị trí file: `frontend/src/pages/EmployeeDashboard.tsx` (dòng ~580)

Mô tả lỗi: Trong bảng hiển thị lịch sử đơn, ô Lý do (`req.reason`) được đặt thuộc tính `whitespace-nowrap overflow-visible`. Khi nhập chuỗi liền nhau không dấu cách, ô dữ liệu bị kéo giãn vô hạn theo chiều ngang.

Hậu quả: Đẩy các cột quan trọng (Số ngày, Trạng thái, Thao tác) văng ra khỏi màn hình, gây thanh cuộn ngang khó chịu và phá vỡ UI Responsive.

Các bước tái hiện (Steps to Reproduce):

1. Đăng nhập với tài khoản nhân viên (VD: `an.nguyen@company.vn`).
2. Tại form xin nghỉ phép, chọn ngày và loại phép. Tại ô **Lý do nghỉ**, nhập chuỗi ký tự liền nhau (VD: `https://jira.company.vn/browse/LONG-TASK-KEY-WITHOUT-SPACE-FOR-TESTING`).
3. Bấm "**Nộp đơn xin nghỉ phép**".
4. Quan sát bảng "Lịch sử đơn của tôi": Bảng bị vỡ layout ngang, nút thao tác bị trôi ra ngoài.

Kết quả thực tế: Cột bảng kéo giãn không giới hạn. **Mong đợi:** Chuỗi dài phải tự động ngắt dòng hoặc rút gọn kèm tooltip.

Cách khắc phục (Fix): Thêm class CSS `truncate max-w-xs` hoặc `break-words`:

```
      <div className="text-xs text-slate-500 truncate max-w-xs" title={req.reason}>
{req.reason} </div>
```

🟡 BUG-02-MEDIUM: Lỗi gửi đơn trùng lặp do thiếu Debounce

Vị trí file: `frontend/src/pages/EmployeeDashboard.tsx` (dòng ~490)

Mô tả lỗi: Nút `[Nộp đơn xin nghỉ phép]` bị loại bỏ `disabled={submitting}`. Khi người dùng double-click nhanh lúc mạng lag, trình duyệt gửi 2 request `POST /api/leave/request` song song. Cả 2 qua được bước kiểm tra BR-13 do chưa kịp ghi DB.

Hậu quả: Tạo ra 2 bản ghi đơn nghỉ phép giống hệt nhau, gây hoang mang cho quản lý và nguy cơ trừ đúp quỹ phép.

Các bước tái hiện:

1. Đăng nhập tài khoản nhân viên và điền thông tin form.

🔴 BUG-03-HIGH: Lỗ hổng IDOR cho phép rút đơn của người khác

Vị trí file: `backend/src/leave/leave.service.ts` (hàm `recallRequest`, dòng ~320)

Mô tả lỗi: Lập trình viên đã vô tình comment dòng code kiểm tra quyền sở hữu đơn. API `DELETE /api/leave/request/:id/recall` không kiểm tra xem đơn đó có thuộc về người dùng đang đăng nhập hay không.

Hậu quả (IDOR - OWASP API Security Top 1): Bất kỳ user nào (dù là thử việc) cũng có thể hủy đơn của đồng nghiệp, trưởng phòng nếu biết được `requestId`, vi phạm nghiêm trọng tính toàn vẹn hệ thống.

Các bước tái hiện:

1. Đăng nhập bằng NV A (`an.nguyen@...`). Tạo đơn mới và copy `id` của đơn (VD: `d9e8f7...`) từ tab Network. Đăng xuất.
2. Đăng nhập bằng NV B (`linh.dang@...`).
3. Mở Console trình duyệt (F12) của NV B, chạy lệnh fetch rút đơn của NV A:

```
fetch('/api/leave/request/ID_DON_CUA_NGUYEN_VAN_AN/recall', { method: 'DELETE', headers: { 'Authorization': 'Bearer ' + localStorage.getItem('token') } }).then(res => res.json()).then(console.log);
```

Kết quả thực tế: Trả về `HTTP 200 OK`. Đơn của NV A bị hủy bởi NV B. **Mong đợi:** Server trả về `403 Forbidden`.

Cách khắc phục: Kích hoạt lại khối lệnh kiểm tra trong service:

```
if (leave.userId !== userId) { throw new ForbiddenException('Bạn không có quyền rút đơn của nhân viên khác.'); }
```

4. Hướng dẫn dành cho Giáo viên / Người đánh giá (SQA Evaluator)

Cả 3 lỗi trên đã được cấy trực tiếp vào mã nguồn của dự án và có chú thích rõ ràng bằng comment:

- `[INJECTED_BUG: BUG-01-LOW ...]`
- `[INJECTED_BUG: BUG-02-MEDIUM ...]`
- `[INJECTED_BUG: BUG-03-HIGH ...]`

Các bạn sinh viên / tester có thể sử dụng các kịch bản kiểm thử sau để phát hiện:

1. **UI Boundary Testing:** Nhập chuỗi độ dài cực đại không có khoảng trắng.